CTF Writeup

Secure App — CTF Writeup

Platform: Perfect Root (AfricaHackon) **Room:** Secure App **Author:** LordSudo **Difficulty:** Easy **Points:** 100 **Category:** Mobile / Android **Result:** Solved (1/1 flag captured)

Description

> A mobile app was flagged during a third-party review. The developers insist no secrets are exposed client-side.

Vulnerability

Hardcoded credential inside the APK (CWE-798: Use of Hard-coded Credentials). A `static final String` API key was shipped in `ApiConfig.smali` and is trivially recoverable after decompilation.

Flag

`r00t{h4rdc0d3d_s3cr3ts_4r3_n3v3r_s4f3}`

Steps

1. Unzipped the provided archive → `secureapp.apk`
2. Decompiled with apktool: apktool d secureapp.apk -o out
3. Grepped the decompiled sources: grep -rin “flag|secret|key|token” out/
4. Located the hardcoded key in `out/smali/com/example/secureapp/ApiConfig.smali`: .field public static final API_KEY:Ljava/lang/String; = “r00t{…}”
5. Submitted the flag.

Lesson

Anything shipped inside an APK is client-side and therefore recoverable. Hardcoded secrets are broken by design. Secrets should be fetched at runtime, stored in the Android Keystore, or — better — never shipped to the client at all.

Tools Used

apktool, jadx (optional), grep, unzip